

Política de Segurança da Informação

1. Objetivo

Estabelecer os princípios, diretrizes e responsabilidades que orientam a proteção dos ativos de informação da organização, visando assegurar que as informações corporativas, independentemente de sua forma de armazenamento, processamento ou transmissão, sejam protegidas de maneira adequada contra acessos não autorizados, alterações indevidas, perda, vazamento ou qualquer outro evento que possa comprometer sua segurança.

Estabelecer os fundamentos necessários para a implementação de práticas e controles que garantam a confidencialidade, integridade e disponibilidade das informações, assegurando que dados e sistemas estejam acessíveis apenas a usuários autorizados, permaneçam corretos e íntegros ao longo do tempo e estejam disponíveis sempre que necessários para a continuidade das operações da organização.

Esta política tem como finalidade promover uma cultura organizacional voltada à segurança da informação, orientando os empregados, parceiros e terceiros quanto às responsabilidades relacionadas à proteção das informações e ao uso adequado dos recursos tecnológicos da organização.

2. Documentos de Referência

Esta Política de Segurança da Informação é complementada por políticas, normas e procedimentos específicos que detalham os controles de segurança adotados pela organização.

Entre os principais documentos relacionados, destacam-se:

- **POL-CMP-02** - Política de Cibersegurança
- **POL-CMP-03** - Política de Privacidade
- **POL-CMP-04** - Política de Utilização Recursos TI
- **POL-CMP-05** - Política de Controle de Acesso
- **POL-CMP-06** - Política de Backup e Recuperação
- **PR-CMP-01-00-00** - Procedimento de Gestão de Incidentes de Segurança
- **PR-CMP-02-00-00** - Procedimento de Gestão de Vulnerabilidades

- **Lei Geral de Proteção de Dados Pessoais:** legislação brasileira que estabelece regras para o tratamento e a proteção de dados pessoais, bem como direitos dos titulares e responsabilidades das organizações no tratamento dessas informações.
- **Diretrizes e orientações da Autoridade Nacional de Proteção de Dados:** órgão regulador responsável por fiscalizar e orientar a aplicação da legislação de proteção de dados no Brasil.
- **ISO/IEC 27001:** norma internacional que estabelece requisitos para implementação, manutenção e melhoria contínua de um Sistema de Gestão de Segurança da Informação (SGSI).

Esses documentos devem ser observados conjuntamente com esta política para garantir a adequada proteção dos ativos de informação da organização.

3. Aplicação

Aplica-se a todos os empregados, prestadores de serviço, parceiros, fornecedores e demais terceiros que, direta ou indiretamente, tenham acesso às informações, sistemas ou recursos tecnológicos da organização, abrangendo todos os ativos de informação utilizados ou gerenciados pela organização, incluindo dados corporativos, documentos, registros eletrônicos, sistemas de informação, aplicações, redes de comunicação, equipamentos computacionais e demais recursos de tecnologia da informação.

Também estão contemplados neste escopo todos os ambientes tecnológicos utilizados pela organização, independentemente de sua localização ou forma de hospedagem, incluindo infraestrutura local, ambientes em nuvem, dispositivos corporativos e quaisquer outros meios utilizados para armazenamento, processamento ou transmissão de informações.

4. Termos e Definições

Para fins desta Política, aplicam-se as seguintes definições:

- **Usuário:** Pessoa que utiliza algum recurso ou serviço de TI da Espiral.
- **Conta de Usuário:** Identificação individual utilizada para acesso aos sistemas e redes.
- **TI:** Tecnologia da Informação.
- **Recursos de TI:** Computadores, redes, servidores, sistemas, e-mail, impressoras, FTP, VPN, RDS, entre outros ativos tecnológicos.
- **FTP (File Transfer Protocol):** Protocolo para transferência de arquivos em rede.
- **VPN (Virtual Private Network):** Serviço de autenticação que permite conexão segura à rede interna.
- **RDS (Remote Desktop Services):** Serviço de acesso remoto a estações ou servidores.
- **CPD:** Centro de Processamento de Dados.
- **LGPD:** Lei Geral de Proteção de Dados

5. Princípios da Segurança da Informação

A segurança da informação na organização é orientada por princípios fundamentais que estabelecem as bases para a proteção adequada dos ativos de informação e para a definição de controles e práticas de segurança. Esses princípios têm como objetivo garantir que as informações sejam protegidas ao

longo de todo o seu ciclo de vida, desde sua criação até seu armazenamento, processamento, compartilhamento e descarte.

Os principais princípios adotados pela organização incluem:

5.1 Confidencialidade

Refere-se à proteção das informações contra acesso, divulgação ou uso não autorizado. As informações devem ser acessadas apenas por pessoas, sistemas ou processos devidamente autorizados, conforme suas responsabilidades e necessidades operacionais.

5.2 Integridade

Refere-se à garantia de que as informações permaneçam completas, corretas e protegidas contra alterações não autorizadas ou indevidas. A integridade assegura que os dados mantenham sua precisão e consistência durante todo o seu ciclo de vida.

5.3 Disponibilidade

Refere-se à garantia de que as informações e os sistemas estejam acessíveis e utilizáveis sempre que necessário para a execução das atividades da organização, respeitando os níveis de serviço e as necessidades operacionais.

Além desses pilares fundamentais, a organização também considera outros princípios complementares que fortalecem a gestão da segurança da informação, conforme item 5.4.

5.4 Princípios Complementares

5.4.1 Autenticidade

Refere-se à garantia de que usuários, sistemas e processos sejam devidamente identificados e autenticados, assegurando que as partes envolvidas em uma transação ou comunicação sejam realmente quem afirmam ser.

5.4.2 Rastreabilidade

Refere-se à capacidade de registrar e acompanhar as ações realizadas em sistemas e informações, permitindo identificar quem realizou determinada atividade, quando ocorreu e quais recursos foram utilizados.

5.4.3 Responsabilidade

Refere-se ao compromisso de todos os usuários em cumprir as diretrizes estabelecidas nesta política e em utilizar os recursos de informação da organização de forma segura, ética e alinhada às normas internas e aos requisitos legais aplicáveis.

Esses princípios orientam a implementação de controles e práticas de segurança adotados pela organização, contribuindo para a proteção adequada das informações e para a confiabilidade dos processos e sistemas utilizados.

6. Classificação da Informação

A organização estabelece diretrizes para a classificação das informações com o objetivo de garantir que os ativos informacionais recebam níveis adequados de proteção, de acordo com sua sensibilidade,

criticidade e impacto potencial em caso de acesso não autorizado, alteração indevida ou indisponibilidade.

A classificação da informação permite que a organização aplique controles proporcionais ao nível de risco associado aos dados e informações sob sua responsabilidade, contribuindo para a proteção de informações estratégicas, operacionais e dados pessoais.

Todos os empregados, prestadores de serviço e usuários autorizados devem tratar as informações da organização de acordo com a classificação atribuída, respeitando as diretrizes de armazenamento, compartilhamento e descarte estabelecidas nesta política e em normas complementares.

6.1 Níveis de Classificação da Informação

As informações devem ser classificadas conforme os seguintes níveis de sensibilidade:

6.1.1 Informação Pública

Informações que podem ser divulgadas ao público sem restrições e cuja divulgação não causa impactos negativos à organização. Exemplos incluem materiais institucionais, conteúdos de divulgação e informações publicadas em canais oficiais.

6.1.2 Informação de Uso Interno

Informações destinadas ao uso interno da organização, cujo acesso deve ser restrito a empregados e usuários autorizados. Embora não sejam altamente sensíveis, sua divulgação externa não autorizada pode causar impactos operacionais ou administrativos.

6.1.2 Informação Confidencial

Informações sensíveis cujo acesso deve ser restrito a um grupo específico de pessoas autorizadas. A divulgação não autorizada pode causar impactos relevantes à organização, incluindo prejuízos financeiros, operacionais ou reputacionais.

6.1.2 Informação Restrita

Informações de alta sensibilidade que exigem níveis elevados de proteção. Incluem informações estratégicas, dados críticos do negócio e dados pessoais sensíveis. O acesso a essas informações devem ser rigorosamente controladas e limitadas a usuários estritamente autorizados.

6.2 Armazenamento de Informações

As informações devem ser armazenadas em ambientes adequados e protegidos, considerando sua classificação e criticidade. Devem ser adotadas medidas de proteção apropriadas, incluindo controles de acesso, mecanismos de proteção de dados e práticas seguras de armazenamento físico ou digital.

Informações classificadas como confidenciais ou restritas devem ser armazenadas em sistemas ou ambientes que ofereçam níveis adequados de proteção e controle de acesso.

6.3 Compartilhamento de Informações

O compartilhamento de informações deve ocorrer apenas quando necessário para a execução das atividades profissionais e sempre respeitando a classificação atribuída à informação.

Informações classificadas como confidenciais ou restritas não devem ser compartilhadas com pessoas ou entidades externas à organização sem autorização formal ou sem a adoção de medidas adequadas de proteção, como acordos de confidencialidade ou mecanismos seguros de transferência de dados.

Quando o compartilhamento envolver dados pessoais, devem ser observadas as diretrizes estabelecidas na Lei Geral de Proteção de Dados Pessoais.

6.4 Descarte de Informações

O descarte de informações deve ser realizado de forma segura, garantindo que dados sensíveis ou confidenciais não possam ser recuperados após sua eliminação.

Documentos físicos contendo informações classificadas devem ser destruídos por meio de métodos seguros, como fragmentação ou descarte controlado. Informações armazenadas em meios digitais devem ser eliminadas utilizando procedimentos que impeçam sua recuperação indevida.

Procedimentos específicos relacionados ao armazenamento seguro, compartilhamento e descarte de informações podem ser definidos em normas e procedimentos operacionais complementares da organização, alinhados às boas práticas de segurança da informação estabelecidas na ISO/IEC 27001.

7. Governança de Segurança da Informação

A governança de segurança da informação estabelece a estrutura de responsabilidades e papéis necessários para garantir a proteção adequada dos ativos de informação da organização. A segurança da informação é um compromisso institucional que envolve diferentes níveis da organização, desde a alta administração até os usuários que utilizam os recursos tecnológicos no dia a dia.

A definição clara de responsabilidades contribui para assegurar que as diretrizes desta política sejam efetivamente implementadas, monitoradas e continuamente aprimoradas.

7.1 Diretoria

A Diretoria é responsável por apoiar e promover a implementação desta Política de Segurança da Informação, garantindo que existam recursos, processos e diretrizes adequadas para a proteção dos ativos de informação da organização. Também cabe à Diretoria incentivar uma cultura organizacional voltada à segurança da informação e assegurar que os riscos relacionados à segurança sejam considerados nos processos de tomada de decisão.

7.2 Tecnologia da Informação (TI)

A área de Tecnologia da Informação é responsável por implementar e manter os controles técnicos necessários para proteger os sistemas, redes, equipamentos e ambientes tecnológicos utilizados pela organização. Compete à área de TI assegurar a disponibilidade e a segurança da infraestrutura tecnológica, bem como apoiar a implementação das diretrizes estabelecidas nesta política.

7.3 Segurança da Informação

A função de Segurança da Informação, quando formalmente designada, é responsável por estabelecer diretrizes, apoiar a gestão de riscos de segurança, acompanhar a implementação de controles de proteção e orientar as áreas da organização quanto às boas práticas de segurança da informação.

7.4 Usuários

Todos os empregados e usuários autorizados que utilizam sistemas, equipamentos ou informações da organização são responsáveis por seguir as diretrizes estabelecidas nesta política, utilizar os recursos tecnológicos de forma segura e reportar qualquer situação que possa representar risco à segurança da informação através do e-mail contato.dpo@espiral.eng.br.

7.5 Terceiros

Fornecedores, prestadores de serviço, parceiros e demais terceiros que tenham acesso a sistemas ou informações da organização devem cumprir os requisitos de segurança estabelecidos nesta política, bem como as cláusulas contratuais relacionadas à proteção das informações e ao uso adequado dos recursos tecnológicos.

8. Gestão de Ativos de Informação

A organização estabelece diretrizes para a identificação, registro, classificação, utilização e proteção adequada de seus ativos de informação, com o objetivo de garantir a segurança, integridade, disponibilidade e rastreabilidade das informações utilizadas em suas operações.

São considerados ativos de informação todos os elementos que suportam o armazenamento, processamento, transmissão ou utilização de informações relevantes para a organização, incluindo recursos tecnológicos, dados, sistemas, documentos e conhecimentos institucionais.

A adequada gestão desses ativos é fundamental para reduzir riscos de segurança da informação, assegurar a continuidade das operações e garantir conformidade com requisitos legais e regulatórios aplicáveis, incluindo aqueles previstos na Lei Geral de Proteção de Dados Pessoais.

8.1 Identificação e Inventário de Ativos

Todos os ativos de informação relevantes para as atividades da organização devem ser identificados e registrados em inventário apropriado. Esse inventário deve incluir, sempre que aplicável:

- sistemas de informação
- bases de dados
- servidores
- equipamentos de rede
- estações de trabalho
- dispositivos móveis
- aplicações corporativas
- serviços em nuvem
- documentos físicos e digitais
- repositórios de dados

O inventário deve ser mantido atualizado e revisado periodicamente, garantindo que novos ativos sejam devidamente registrados e ativos descontinuados sejam removidos ou tratados conforme os procedimentos estabelecidos pela organização.

8.2 Responsáveis pelos Ativos

Cada ativo de informação deve possuir um responsável formalmente designado, também denominado proprietário do ativo. Esse responsável é encarregado de:

- garantir a correta classificação da informação associada ao ativo;
- definir níveis de acesso apropriados;
- assegurar o uso adequado do ativo;
- apoiar a implementação de controles de segurança necessários para sua proteção.

Os responsáveis pelos ativos devem atuar em conjunto com as áreas de Tecnologia da Informação e Segurança da Informação sempre que necessário.

8.3 Uso Adequado dos Ativos

Os ativos de informação da organização devem ser utilizados exclusivamente para finalidades profissionais e institucionais autorizadas. O uso inadequado, não autorizado ou em desacordo com as diretrizes estabelecidas pode comprometer a segurança das informações e gerar riscos operacionais, legais e reputacionais.

Todos os usuários que utilizam ativos de informação da organização devem observar as diretrizes estabelecidas nesta política, bem como em normas complementares relacionadas ao uso aceitável de recursos tecnológicos.

8.4 Proteção dos Ativos de Informação

Os ativos de informação devem ser protegidos de acordo com sua classificação e criticidade para o negócio. Essa proteção pode incluir, entre outras medidas:

- controles de acesso lógico e físico;
- criptografia de dados;
- monitoramento de atividades;
- backups e mecanismos de recuperação;
- controles de segurança em sistemas e infraestrutura.

Os controles técnicos específicos aplicáveis à proteção dos ativos são definidos em políticas e procedimentos complementares de segurança da informação e cibersegurança da organização, alinhados às boas práticas estabelecidas na ISO/IEC 27001.

8.5 Descarte e Descontinuidade de Ativos

Quando um ativo de informação atingir o fim de seu ciclo de vida ou deixar de ser utilizado, deve ser adotado procedimento seguro para seu descarte, substituição ou descontinuidade.

Esse processo deve assegurar que informações sensíveis ou dados pessoais não permaneçam acessíveis ou recuperáveis após o descarte do ativo, evitando riscos de exposição indevida de informações.

9. Uso Aceitável de Recursos Tecnológicos

A organização estabelece diretrizes para o uso adequado dos recursos tecnológicos disponibilizados aos empregados, terceiros e demais usuários autorizados, com o objetivo de garantir a segurança das informações, a integridade dos sistemas e o uso responsável da infraestrutura tecnológica.

Os recursos tecnológicos da organização são disponibilizados exclusivamente para fins profissionais e institucionais, devendo ser utilizados de forma ética, responsável e em conformidade com as diretrizes

estabelecidas nesta Política de Segurança da Informação e em normas complementares relacionadas à segurança e proteção de dados.

O uso inadequado ou não autorizado desses recursos pode comprometer a segurança da informação, gerar riscos operacionais, causar danos à reputação da organização e resultar em responsabilidades legais.

9.1 Uso de Computadores e Equipamentos Corporativos

Os computadores, notebooks e demais equipamentos tecnológicos fornecidos pela organização devem ser utilizados prioritariamente para a execução de atividades profissionais. Os usuários são responsáveis por zelar pela integridade dos equipamentos sob sua responsabilidade e por evitar qualquer utilização que possa comprometer sua segurança ou funcionamento.

Não é permitido:

- instalar softwares não autorizados pela área de Tecnologia da Informação;
- desativar mecanismos de segurança implementados nos equipamentos;
 - utilizar dispositivos corporativos para atividades ilícitas ou que possam comprometer a segurança da organização.

9.2 Uso do E-mail Corporativo

O e-mail corporativo é uma ferramenta de comunicação profissional e deve ser utilizado exclusivamente para atividades relacionadas às funções desempenhadas pelo usuário na organização.

Os usuários devem evitar o envio ou recebimento de conteúdos que possam representar risco à segurança da informação, incluindo arquivos suspeitos, links desconhecidos ou mensagens de origem duvidosa.

Mensagens eletrônicas enviadas por meio do e-mail corporativo podem ser monitoradas ou auditadas pela organização quando necessário, respeitando os limites legais aplicáveis.

9.3 Uso da Internet

O acesso à internet disponibilizado pela organização deve ser utilizado de forma responsável e alinhada às atividades profissionais.

Não é permitido utilizar a rede corporativa para:

- acessar conteúdos ilícitos ou inadequados;
- realizar downloads de softwares ou arquivos sem autorização;
- acessar sites que representem risco à segurança da rede corporativa.

A organização poderá adotar mecanismos de monitoramento e controle de acesso à internet com o objetivo de proteger sua infraestrutura tecnológica e prevenir incidentes de segurança.

9.4 Uso de Dispositivos Móveis

Dispositivos móveis utilizados para acesso a sistemas ou informações da organização devem observar requisitos mínimos de segurança, incluindo proteção por senha, bloqueio automático e atualização periódica de sistemas e aplicações.

Quando dispositivos móveis forem utilizados para acessar informações corporativas, os usuários devem adotar cuidados adicionais para evitar perda, roubo ou acesso não autorizado às informações.

Diretrizes técnicas específicas relacionadas à segurança de dispositivos móveis são definidas em políticas e procedimentos complementares de segurança da informação e cibersegurança.

9.5 Uso de Sistemas Corporativos

O acesso aos sistemas corporativos deve ocorrer exclusivamente por usuários devidamente autorizados e dentro dos limites de acesso definidos para suas funções.

Os usuários são responsáveis por manter a confidencialidade de suas credenciais de acesso e por não compartilhar senhas ou permissões com terceiros.

A gestão técnica de acessos, autenticação e monitoramento de sistemas é definida em políticas específicas de segurança da informação e cibersegurança, alinhadas às boas práticas estabelecidas na ISO/IEC 27001.

10. Gestão de Riscos de Segurança da Informação

A organização estabelece diretrizes para a identificação, análise e tratamento de riscos relacionados à segurança da informação, com o objetivo de proteger seus ativos informacionais, reduzir vulnerabilidades e garantir a continuidade das operações.

A gestão de riscos de segurança da informação consiste em um processo contínuo e estruturado destinado a identificar ameaças, avaliar vulnerabilidades e determinar o impacto potencial de incidentes que possam comprometer a confidencialidade, integridade ou disponibilidade das informações da organização.

Esse processo deve considerar riscos associados a sistemas de informação, infraestrutura tecnológica, processos operacionais, tratamento de dados e interação com terceiros.

10.1 Identificação de Riscos

A organização deve identificar periodicamente os riscos que possam afetar a segurança de seus ativos de informação. Essa identificação deve considerar, entre outros fatores:

- ameaças internas e externas;
- vulnerabilidades em sistemas e infraestrutura;
- falhas de processos ou controles;
- riscos associados a fornecedores e terceiros;
- riscos relacionados ao tratamento de dados pessoais.

A identificação de riscos deve abranger tanto ambientes tecnológicos quanto processos organizacionais que envolvam o tratamento ou a gestão de informações.

10.2 Avaliação de Impacto e Probabilidade

Após a identificação dos riscos, deve ser realizada a avaliação do impacto potencial que um incidente de segurança poderia causar à organização, considerando aspectos operacionais, financeiros, legais, regulatórios e reputacionais.

A análise também deve considerar a probabilidade de ocorrência de cada risco identificado, permitindo a priorização das ações de mitigação conforme o nível de criticidade associado.

Essa avaliação deve permitir a classificação dos riscos em diferentes níveis de severidade, apoiando a tomada de decisão sobre a implementação de controles de segurança adequados.

11. Monitoramento da Conformidade

A organização poderá realizar atividades de monitoramento com o objetivo de verificar a aderência às diretrizes estabelecidas nesta política e em normas complementares de segurança da informação.

Esse monitoramento pode incluir, entre outras atividades:

- verificação do cumprimento de controles de segurança;
- análise de registros de acesso a sistemas e informações;
- acompanhamento da implementação de medidas de segurança;
- avaliação de práticas operacionais relacionadas à proteção de dados e informações.

As atividades de monitoramento devem respeitar os limites legais aplicáveis e considerar princípios de proporcionalidade, necessidade e transparência.

11.1 Auditorias Internas

Auditorias internas de segurança da informação podem ser realizadas periodicamente com o objetivo de avaliar a eficácia dos controles adotados, identificar oportunidades de melhoria e verificar o cumprimento das diretrizes estabelecidas nesta política e em documentos correlatos.

As auditorias podem abranger processos organizacionais, sistemas de informação, infraestrutura tecnológica, práticas operacionais e controles relacionados à segurança da informação e à proteção de dados.

Os resultados das auditorias devem ser documentados e, quando aplicável, utilizados para orientar ações corretivas, preventivas ou de melhoria contínua nos processos de segurança da informação.

11.2 Cumprimento das Diretrizes

Todos os usuários que utilizam sistemas, equipamentos ou informações da organização devem cumprir as diretrizes estabelecidas nesta política. O descumprimento das normas de segurança da informação pode resultar na adoção de medidas administrativas, disciplinares ou contratuais, conforme aplicável.

O Grupo Espiral promove mecanismos de acompanhamento e avaliação contínua da conformidade com esta política, garantindo que as práticas de segurança da informação estejam alinhadas às boas práticas reconhecidas internacionalmente, incluindo aquelas estabelecidas na ISO/IEC 27001, bem como às obrigações relacionadas à proteção de dados previstas na Lei Geral de Proteção de Dados Pessoais.

7. Registros do Documento

Classificação:	Corporativo.
Código e Revisão:	POL-CMP-01, Rev00
Emissão:	Dieni Derito, André Pinho, Raustan Santos, Marcus Bernardes, Cristiano Moraes
Aprovação:	André Pinho, Fernando Altoé
Descrição da alteração:	Emissão Inicial
Data:	29/04/2026